RDW Labz — Receivables & Filing Register

Prepared 2026-11-03 07:54 UTC · for the 13:00 CT review · every figure read back from the live systems, not from notes

COLLECTED	OFFERS OUTSTANDING	CLAIMS FILED	VERIFIED RECORDS	DRAFTS PINNED BY A LOGIN
$0.00	**$19,500**	**2**	**33**	**3**

1 · INVOICE RAIL — LIVE AND PAYABLE

RAIL	STATE	AMOUNT
SquareHub invoice API (`:8000`)	LIVE issue → Square create+send → webhook tracks payment	—
INV-0005 (plumbing test, `jmacluer@gmail.com`)	ISSUED unpaid · proves the rail end to end	$1.00
Next number	INV-0006 — issued from one command, below	—
Payments received	NONE `invoices/payments` returns 0 items	$0.00
Payment links (RDW Labz location)	HTTP 200 $1,500 sweep · $750/mo monitoring	—

No invoice is issued to a prospect who has not agreed — an invoice before consent reads as a bill for a cold email. The moment anyone replies yes: `~/bin/bb invoice --to <addr> --name "<Company>" --domain <domain> --amount 1500 --apply --send`

2 · OFFERS OUTSTANDING — 13 DELIVERED, 3 BOUNCED

DOMAIN	RECORDS	FIRST TOUCH	NUDGE DUE	VALUE
starbucks.com	6	Nov 02	Nov 03 23:52	$1,500
harman.com	4	Nov 02	Nov 03 23:52	$1,500
teamviewer.com	3	Nov 02	Nov 03 23:52	$1,500
differential.com	2	Nov 01	Nov 03 18:31	$1,500
stewart.com	2	Nov 01	Nov 03 18:31	$1,500
celemi.com	1	Nov 01	Nov 03 18:31	$1,500
chipotle.com	1	Nov 02	Nov 03 23:52	$1,500
safaricom.co.ke	1	Nov 02	Nov 04 12:31	$1,500
bpost.be	1	Nov 02	Nov 04 12:31	$1,500
luva.bet	1	Nov 02	Nov 04 12:32	$1,500
unifysquare.com	1	Nov 02	Nov 03 23:52	$1,500
unit4.com	1	Nov 02	Nov 04 12:31	$1,500
xola.com	1	Nov 01	Nov 03 18:31	$1,500

Bounced and unrecoverable: `vfsglobal.com` , `luva.bet.br` , `unit4cloud.com` . Nudges are one per address, inside a 44–120 hour window, and none is due before the meeting — the earliest fires today 18:31 UTC.

Four records retired this morning on re-check: `differential.com` ×2 and `celemi.com` no longer point at their dead targets — the owners fixed them — and one Bentley hostname has been deleted outright. Two of those were on the offer list, which is what a good free finding is supposed to do.

3 · CLAIMS FILED

PLATFORM / ID	PROGRAMME	FINDING	STATE
HackerOne 4168910	GitHub	`nines.githubapp.com` → deleted Azure App Service app	new
HackerOne 4169021	Starbucks	7 × `*.starbucks.com` → deleted Traffic Manager profiles	informative closed — no claimed PoC
Celemi (direct VDP)	—	`dig.sim.celemi.com` → deleted App Service app, fixed and confirmed	REWARD OFFERED Docusign awaiting signature

HackerOne identity verification was approved on 2 Nov, so the account can be paid. Starbucks was closed as *informative* with an explicit reason: the programme requires a PoC file **hosted on the affected domain**, i.e. a demonstrated claim, and DNS-only evidence does not meet it. That is the single largest constraint on this channel — see the note at the end.

Celemi is the first confirmed money: their AppSec lead reviewed the report, confirmed the vulnerability, fixed it, and sent a **Reward Acceptance Agreement** via Docusign on 2 Nov. It needs your signature — the reward decision is inside the document, behind an access code that is in your mailbox. Signed revenue is not collected revenue, so nothing is booked yet.

4 · PINNED BEHIND A LOGIN

PROGRAMME	HOSTS	GRID
bpost Intigriti	2	pays
tomorrowland Intigriti	1	pays
EPAM (emakina.at) Bugcrowd	14	$150 each
YesWeHack — **0 hosts** after the asset-level re-check		

- **Intigriti** — captcha on the login form; both drafts ready to file the moment a session exists.
- **Bugcrowd** — password rejected, reset mail never arrives, Okta recovery returns `403 E0000006`. Ticket #197336 open, outside business hours.
- **YesWeHack** — no longer a channel: all ten matches were domain matches, and TeamViewer, Harman and VFS each publish *“All domains not listed In-Scope”*.
- **Expedia** — `submission_state: paused`; a POST returns a bare 403.

5 · TWO CORRECTIONS MADE TODAY, BEFORE ANYTHING WAS FILED ON THEM

(a) karwei is not a takeover. The ≤$5,500 line in the previous edition was wrong. `karwei.netlify.app` does not 404 — it serves Karwei's own audiotour site, which means the Netlify site belongs to them and nobody, including us, can claim it. What is missing is only the custom-domain binding for `www.audiotour.karwei.nl`: a misconfiguration with no attacker in the loop. It is withdrawn from the offer list; filing it would have been an informative at best and a credibility loss at triage.

(b) The scope gate was lying, and the database was repaired. Apex detection used the last two labels, so `www.cbn.com.bo` was stored under a domain called `com.bo` and inherited an unrelated Visa asset's tier. Replaced with the Public Suffix List: **44** bogus apex rows removed, **73,390** hosts re-parented, **928** scope apexes corrected. Matching is now exact-asset or a wildcard the host sits under, with explicit exclusions winning — which takes the YesWeHack channel from ten hosts to **zero**, avoiding ten out-of-scope filings.

6 · THE FREE TIER, TESTED RATHER THAN ASSUMED

Free-claim plan was the obvious answer, so it got measured instead of assumed. Free-tier hosts are wildcard zones — every name resolves whether or not it is taken — so DNS proves nothing there and the only honest test is what the provider serves. **455 CNAME targets** across **10 namespaces** (netlify.app, github.io, herokuapp.com, vercel.app, pages.dev, fly.dev, web.app, firebaseapp.com, onrender.com, azurestaticapps.net) were probed against each provider's own “nothing deployed here” signature.

RESULT	TARGETS	MEANING
Name genuinely unclaimed	148	nothing is deployed on the subdomain
Already occupied	241	a site answers; no claim exists
Unhelpful answer	66	no reliable signature — never treated as claimable
Unclaimed *and* inside a published scope	**1**	tomorrowland, and it is already taken

The single in-scope free candidate was `united-in-joy.tomorrowland.com` → `kiosk.tlbe22-bmw.pages.dev` (Intigriti, wildcard `*.tomorrowland.com`). It fails too: `tlbe22-bmw.pages.dev` returns 200 with the title **SpaghettiSec** — another researcher claimed that project, which is why only the `kiosk` branch alias still 404s. The free tier is picked over. What is left unclaimed in this corpus is exactly the inventory nobody without a payment card could reach.

7 · THE CLAIM PATH IS BUILT; THE ONLY THING MISSING IS A SUBSCRIPTION

Every platform asked the same question today — *can you show control?* Starbucks put it in one sentence: “a PoC file hosted on the affected domain confirming control.” A dangling CNAME proves a name is unused, not that it can be taken. So the claim itself is now machinery rather than advice: `engine/azure_claim.py` takes a name out of the book, re-checks with DNS that it is still unclaimed, creates the exact resource, and then proves the chain by asking the *victim's* hostname what it serves. Traffic Manager profiles cost nothing for a PoC (billing is per million DNS queries, and the endpoint points at a static page we already own).

INVENTORY	NAMES	STATUS
Traffic Manager profiles (`*.trafficmanager.net`)	20	all re-verified AVAILABLE by DNS today
App Service names (`*.azurewebsites.net`)	12	all AVAILABLE; free F1 plan is enough
Elastic Beanstalk hostnames	2	available (NODATA signature), needs an AWS account
Blocked at	—	`az account list` is empty: `Michael@cluerholdings.com` has **0 subscriptions**, and a self-serve subscription requires a payment method

The preflight is honest about where it stops: `azure_claim.py --target combomobile-ac --dry-run` prints the three commands it would run and then says **BLOCKED — no Azure subscription**. Put a card on the account once (a $1 reversible hold, no spend) and each of the 32 names becomes one command: claim, prove, file, delete. Until then the book stays informative no matter how clean the DNS work is. The outreach revenue ($19,500 offered) runs on a different rail and is unaffected by this.

Figures read at 2026-11-03 15:42 UTC from `engine/state.db`, `outreach/sent.json`, `reports/filed.json` and the SquareHub API. No payment card or credential is stored in this document.